

Cyber Risk Executive Summary

First National Bank (Fictional) · Prepared by Ameer Khan · 2026-09-21

Simulated organisation. First National Bank is fictional and all figures are illustrative, produced by a portfolio risk-modelling platform. This document demonstrates analytical method and reporting format, not an assessment of any real institution.

\$19.61M Total annualised loss expectancy	\$5.50M Residual after controls	2.2 / 5.0 NIST CSF maturity	8 Vendors assessed	3 Overdue reassessments
---	---	---------------------------------------	------------------------------	-----------------------------------

Executive Overview

Across five modelled threat scenarios, First National Bank carries an expected annual cyber loss of **\$19.61M**. The largest single exposure is **Ransomware Attack** at \$5.45M per year, with a one-in-ten-year loss of \$14.05M. A control programme costing **\$1.51M annually** is estimated to remove \$14.11M of that exposure, leaving \$5.50M residual.

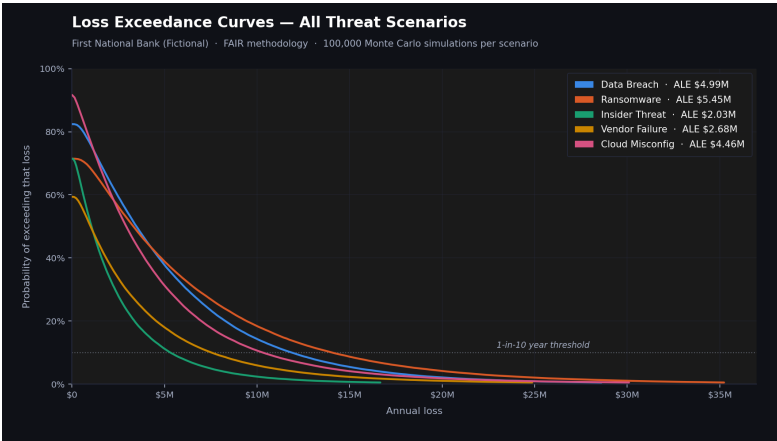
Control maturity is the constraint. The bank scores **2.2 of 5.0** against NIST CSF 2.0, with **Respond** weakest at 1/5. 4 control gaps are open, and 3 of 8 third-party vendors are past their OSFI B-10 reassessment date. Governance and incident response are the two areas where low cost meets high consequence.

1. Quantified Risk Exposure

Each scenario is modelled with the FAIR method: annual event frequency drawn from a Poisson distribution, single-event loss from a log-normal fitted to a low/high range, summed across 100,000 simulated years.

Scenario	Expected annual loss	1-in-10 year	Control cost	Residual ALE	ROSI
Ransomware	\$5.45M	\$14.05M	\$500K	\$1.36M	717%
Data Breach	\$4.99M	\$11.86M	\$350K	\$1.50M	898%
Cloud Misconfig	\$4.46M	\$10.30M	\$180K	\$892K	1,883%
Vendor Failure	\$2.68M	\$7.53M	\$200K	\$937K	770%
Insider Threat	\$2.03M	\$5.31M	\$280K	\$814K	336%
Portfolio total	\$19.61M	—	\$1.51M	\$5.50M	—

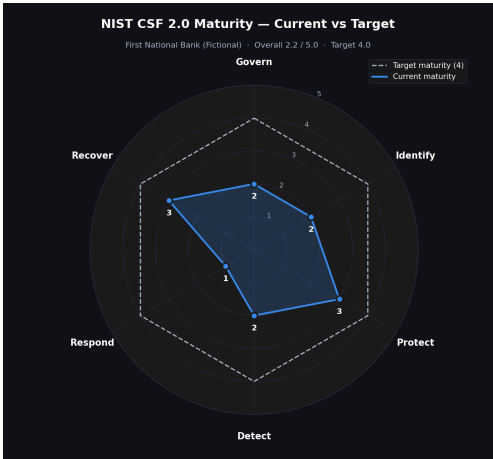
ROSI (return on security investment) = (risk reduced – control cost) ÷ control cost. Control effectiveness is assumed at 60–80% by scenario. Control costs represent incremental tooling spend only and exclude staffing, so ROSI is an upper bound.



Loss exceedance curves. Read the curve at any dollar figure to get the probability that annual losses exceed it.

2. Control Maturity — NIST CSF 2.0

Function	Current	Target	Gap	Assessment
Govern	2	4	+2	No board-approved cybersecurity policy. Risk appetite undocumented.
Identify	2	4	+2	Asset inventory incomplete. Risk assessments are informal and ad hoc.
Protect	3	4	+1	MFA and encryption deployed. Access reviews not yet measured.
Detect	2	4	+2	Logging in place but no active monitoring or alerting thresholds.
Respond	1	4	+3	No documented incident response plan. OSFI 24-hour reporting path undefined.
Recover	3	4	+1	Backups tested annually. Recovery time objectives defined for tier-1 systems only.



Current maturity against a target of 4 (managed and measured) across all six functions.

3. Recommended Actions

Ranked by consequence relative to effort. The first two are low-cost and unblock everything downstream.

1. Govern — Critical (low effort, about 4 weeks)

Without governance, no other function is sustained. B-13 requires documented cyber risk governance with board oversight.

Action: Draft and approve a cybersecurity policy. Document a risk appetite statement. Establish quarterly cyber risk reporting to the board.

Start this month: Draft a one-page cybersecurity policy and obtain executive sign-off this month.

NIST CSF GV.PO-01 · ISO 27001 A.5.1 · SOC 2 CC1.1 · OSFI B-13 — Governance and Risk Management

2. Identify — Critical (medium effort, about 8 weeks)

You cannot protect what you do not know you have. Unknown assets remain the most common initial access point in reported breaches.

Action: Deploy asset discovery tooling. Conduct a formal risk assessment and record findings in a risk register with named owners.

Start this month: Run an authenticated network discovery scan to produce a baseline asset list.

NIST CSF ID.AM-01 · ISO 27001 A.5.9 · SOC 2 CC3.2 · OSFI B-13 — Technology Operations and Resilience

3. Respond — High (low effort, about 6 weeks)

Without a plan, response is improvised. OSFI expects notification of a reportable technology or cyber incident within 24 hours of determination.

Action: Create an incident response plan covering roles, containment and the OSFI 24-hour reporting path. Run a tabletop exercise within 90 days.

Start this month: Name an incident response lead and publish a contact escalation tree this week.

NIST CSF RS.MA-01 · ISO 27001 A.5.24 / A.5.26 · SOC 2 CC7.4 · OSFI Technology and Cyber Security Incident Reporting Advisory (24 hours)

4. Third-Party Risk Snapshot

8 vendors assessed against an OSFI B-10 aligned questionnaire: 1 critical, 2 high, 3 medium and 2 low tier. **3 are past their reassessment date** and should be re-run before any contract renewal.

Vendor	Service	Tier	Score	Critical gaps	Reassessment
Lakeshore Data Systems	IT Infrastructure	Critical	36	3	OVERDUE
Borealis Analytics	Data Analytics / AI	High	51	3	OVERDUE
Acadia Payment Solutions	Payment Processor	High	58	2	OVERDUE
Rideau Infrastructure Group	IT Infrastructure	Medium	66	1	2027-06-18
MapleLedger Payments	Payment Processor	Medium	73	1	2027-03-05
Sable Ridge SaaS	Software / SaaS	Medium	79	0	2027-08-22
Cartier Software Labs	Software / SaaS	Low	83	0	2028-07-22
NorthPeak Cloud Services	Cloud Provider	Low	87	1	2028-05-23

5. OSFI Alignment

Guideline	Scope	Status in this assessment
B-13 (in force Jan 2024)	Technology and cyber risk management	Governance and detection gaps open; incident reporting path undefined
B-10 (in force May 2024)	Third-party risk management	Vendor tiering operating; 3 reassessments overdue
E-21 (full adherence Sep 2026)	Operational risk and resilience	Recovery tested annually; scenario testing of all critical operations due Sep 2027

Method and Limitations

Loss ranges are calibrated to published Canadian financial-sector breach cost benchmarks and interpreted as the 5th and 95th percentile of a log-normal distribution; the resulting mean therefore sits above the midpoint of the stated range. Scenarios are modelled independently, though in practice one event often triggers several. Control effectiveness is assumed rather than measured. Figures should be read as a decision-support range, not a forecast.